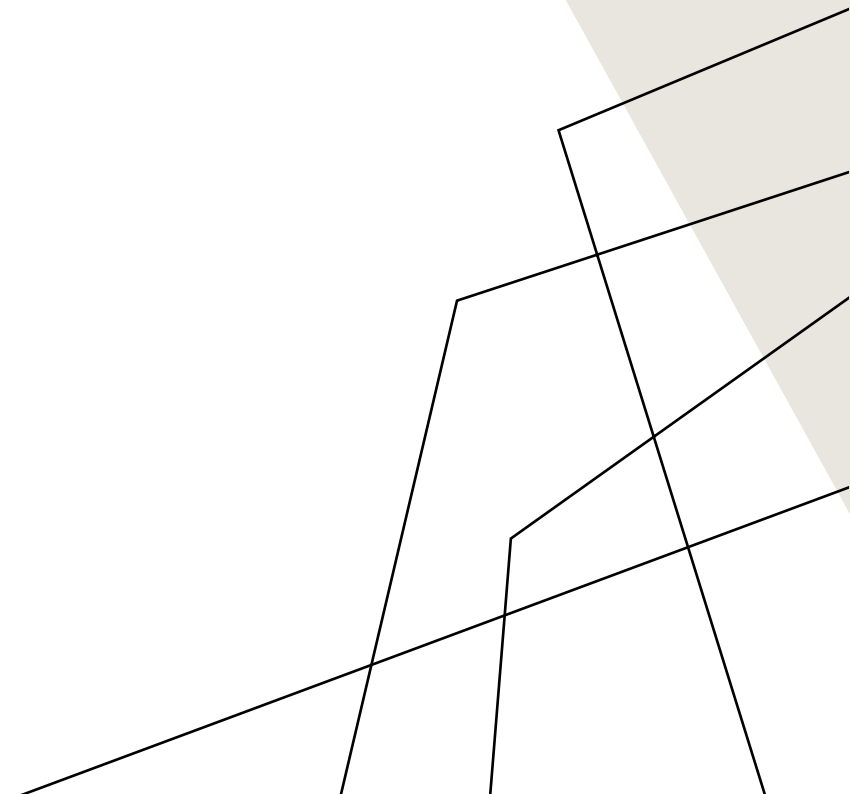


AN INTRO TO C2 FRAMEWORKS

By Shad Brown

WHOAMI.EXE

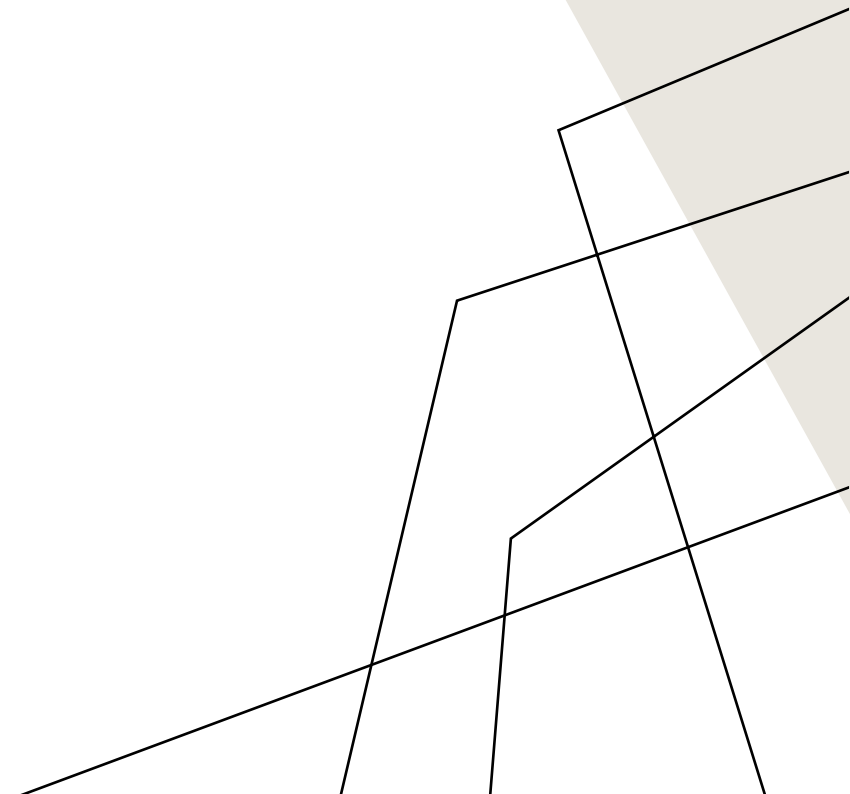
- Worked at 3M as Vulnerability Management Engineer, then Breach and Attack Simulation Engineer
- Starting role as Associate Consultant at SpecterOps on April 14th
- Alphabet Soup of Certifications
  - OSCP, CRTL, CRTO
- BS Cybersecurity from SCSU in 2020
  - CCDC Participant (Before I was penned “The Villian”)
  - Former HuskyTech Lead (Hi Sarah and Bob!)
  - Tech Fee Committee Member
- I can be found online
  - Blog - https://www.winterknight.net
  - LinkedIn - https://www.linkedin.com/in/shadbrown/
  - Bluesky - @winterknight.net
  - Mastodon - @winterknight1337@infosec.exchange
  - Twitter was never good don’t @ me



BEFORE WE BEGIN

STAYING OUT OF JAIL

- Talking about malware
- Malware is a tool, not inherently good or evil
- Use malware responsibly
- Only use malware on systems you own, or have ***written permission*** from the system owner that authorizes you to do so
- Not doing so may violate the the law
- Using malware in illegal ways could get you investigated by the FBI
- I am not responsible for your actions
- It’s not my fault if you use malware in an illegal manner and get caught
- I am not a lawyer



A BRIEF DETOUR – TARGETED ATTACK LIFECYCLE

- Created by Mandiant
  - Evolution of Lockheed Martin's Cyber Kill Chain
- Lifecycle
  - Initial Reconnaissance
  - Initial Compromise
  - Establish Foothold
  - Escalate Privileges
  - Internal Reconnaissance
  - Move Laterally
  - Maintain Presence
  - Complete Mission

https://cloud.google.com/security/resources/insights/targeted-attack-lifecycle

A PROBLEMATIC ATTACK LIFECYCLE

- Initial Reconnaissance
- Initial Compromise
- Establish Foothold
- Escalate Privileges
- Internal Reconnaissance
- Move Laterally
- Maintain Presence
- Complete Mission

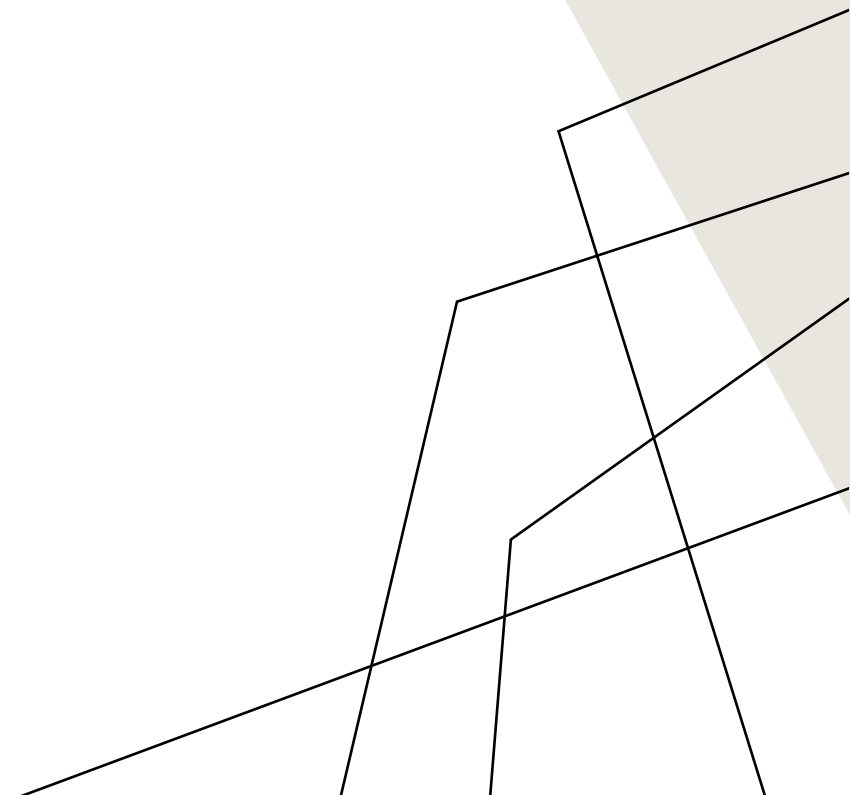
These cause problems for threat actors

Especially this one

https://cloud.google.com/security/resources/insights/targeted-attack-lifecycle

THE PROBLEMS - CONTINUED

- Difficult to remember each shell context
  - Can have many shells by end of engagement
- No Quality-of-Life features (by default)
  - Tab complete
  - Arrow keys are nonfunctional
- Everything goes through the CLI
  - Easily logged with Sysmon or bash history
    - Bad for remaining undetected
- Establishing persistence is tricky
  - Need to manually set up a listener before execution
- Operator logging is non-existent
  - For report writing and deconfliction – super important!



THE PROBLEM ILLUSTRATED

nc nc nc nc nc nc nc nc nc nc nc nc nc nc nc



WHY DO RED TEAMERS LIKE C2?

- Provides single management interface for compromised systems
- Helps remain undetected by security tools
  - Heavily customizable
  - Uses system APIs directly
    - Not run through the CLI
- Contains useful QoL features!
  - Tab complete
  - Functional arrow keys
  - Operator Logging
- Provides methods to easily perform post-exploitation actions
  - Navigating compromised systems
  - Exfiltrating files
  - Escalating privileges
  - Internal Recon

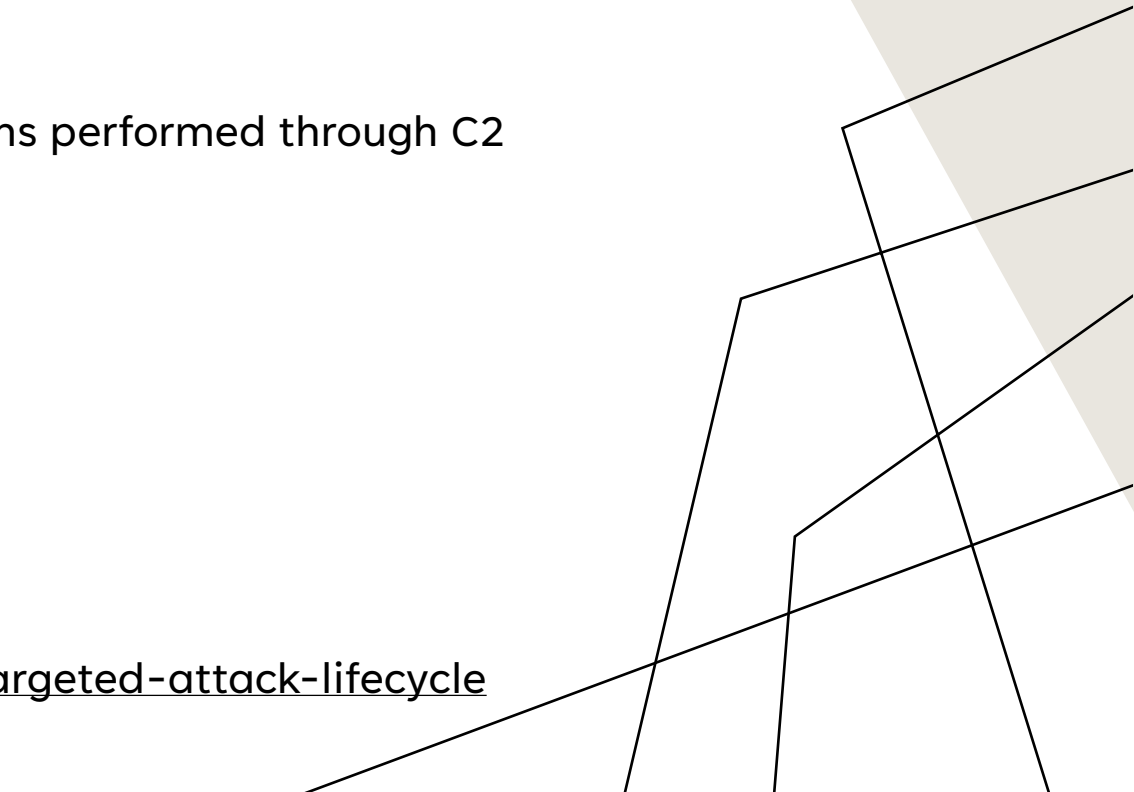
TARGET ATTACK LIFECYCLE (WITH C2!)

- Initial Reconnaissance
- Initial Compromise

C2 Agent Deployed Here

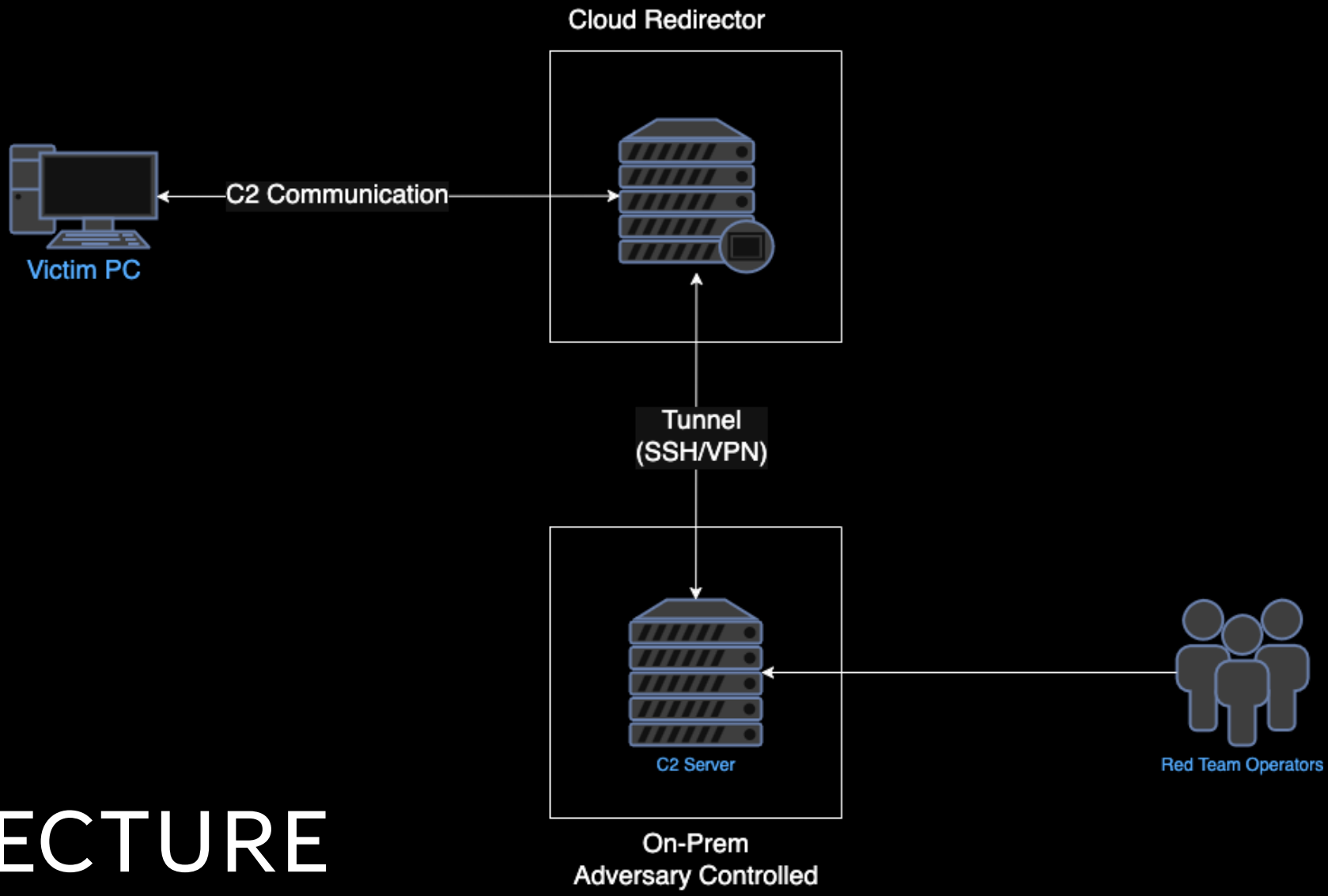
- Establish Foothold
- Escalate Privileges
- Internal Reconnaissance
- Move Laterally
- Maintain Presence
- Complete Mission

Actions performed through C2



https://cloud.google.com/security/resources/insights/targeted-attack-lifecycle

C2 ARCHITECTURE



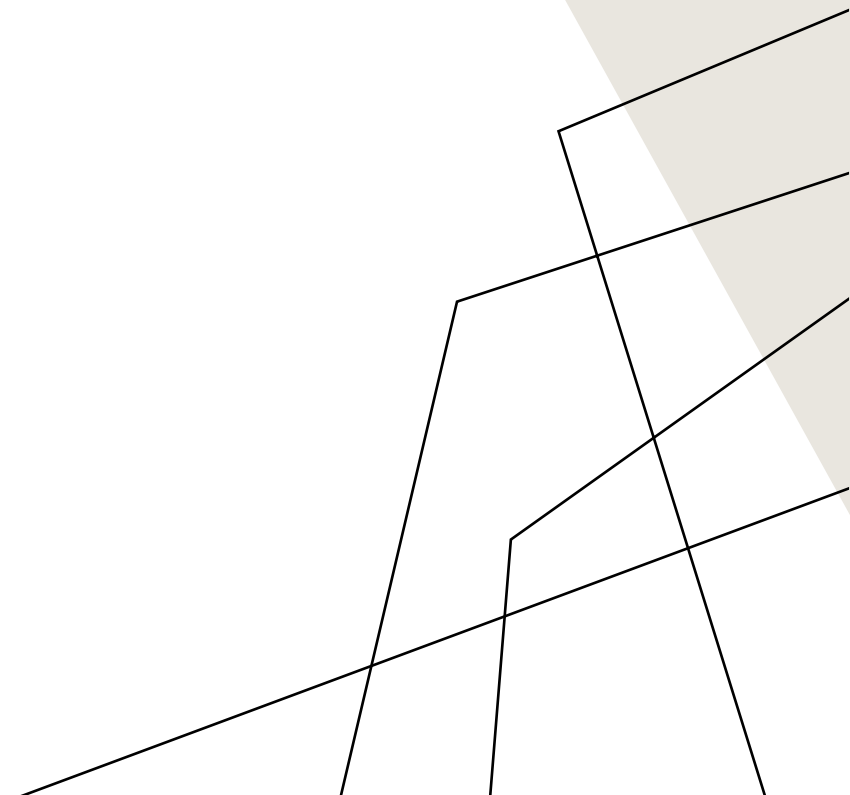
C2 CLIENTS (BOTH SPICY AND MUNDANE)

- Agent
  - This is malware
  - Runs operator-specified commands received from C2 server
    - Can also run external arbitrary executables
  - Communicates back to server over predefined protocols
  - Needs to remain hidden from security software
    - Especially AV and EDR

- Non-malicious clients
  - For operators
  - Used to administer agents installed on victim machines
  - Also used to conduct operational activities
  - May be hosted as a website

C2 SERVERS

- Supports multiple operators working concurrently
- Generates agents
    - Used for initial access and execution under different contexts
- Manages connected agents from a single interface
- Issues commands and awaits outputs
    - Can be single, subset, or all connected agents
- Can also execute arbitrary external payloads
    - Useful for host recon, network recon, privesc
- Logs operational activities for later reporting
- Typically hidden behind non-malicious frontend
    - A friendly looking website



SOME C2 EXAMPLES

Depending on who you ask

https://github.com/cobbr/Covenant

https://www.metasploit.com/

https://github.com/its-a-feature/Mythic



FORTRA
Cobalt Strike

https://www.cobaltstrike.com/

https://github.com/HavocFramework/Havoc

HARDHAT C2

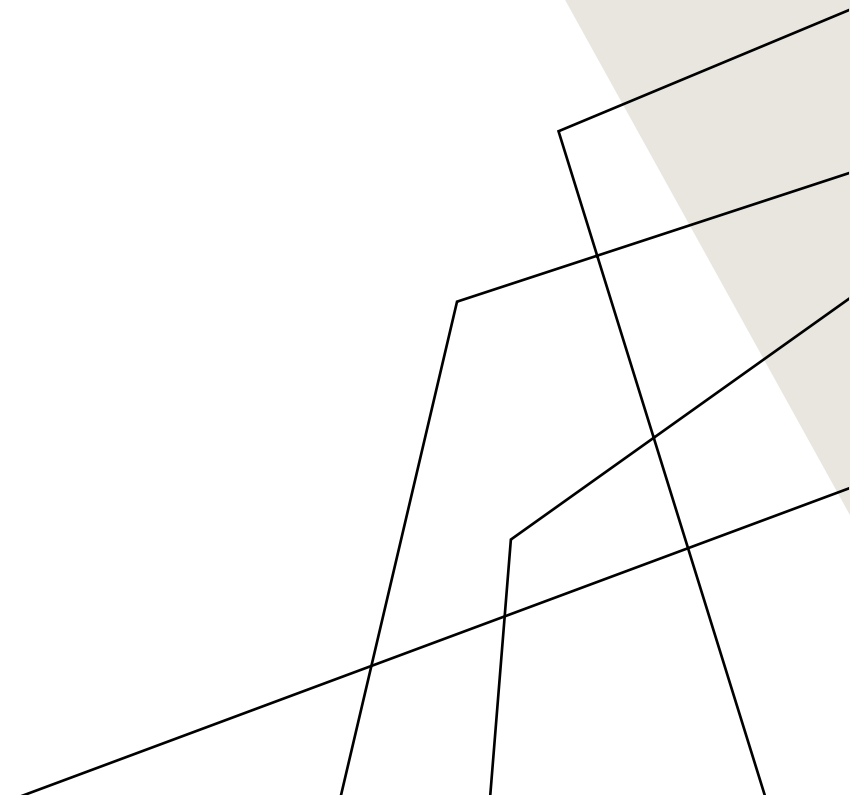
https://github.com/DragoQCC/CrucibleC2

C2 SERVER CONSIDERATIONS

- C2 communicates over common protocols
  - HTTP/S
  - TCP
  - SMB
  - DNS (YES! It’s slow and painful, but technically possible)
- Communication Parameters are customizable by operator
  - Enables blending in with typical network traffic
- Hosted on-prem
  - Routed through “Redirectors”
  - Often obfuscated with a legit looking website

C2 AGENT CONSIDERATIONS

- What OS?
- What architecture?
- Admin user?
- Execution method?
  - GUI?
  - CLI?
- How are you staying undetected?
  - Staying hidden from security tools
  - Staying hidden from end users
  - Does this bring in limitations to how agents operate?
- Is there a communication path to C2 server?
  - Determines communication channel

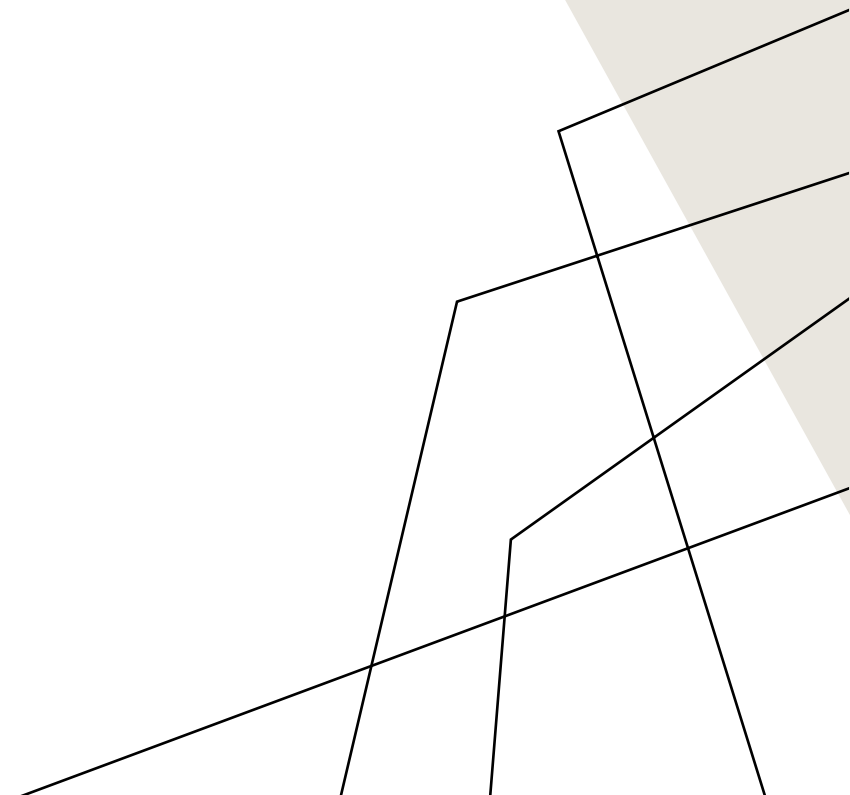




C2 USE CASE EXAMPLES WITH MYTHIC

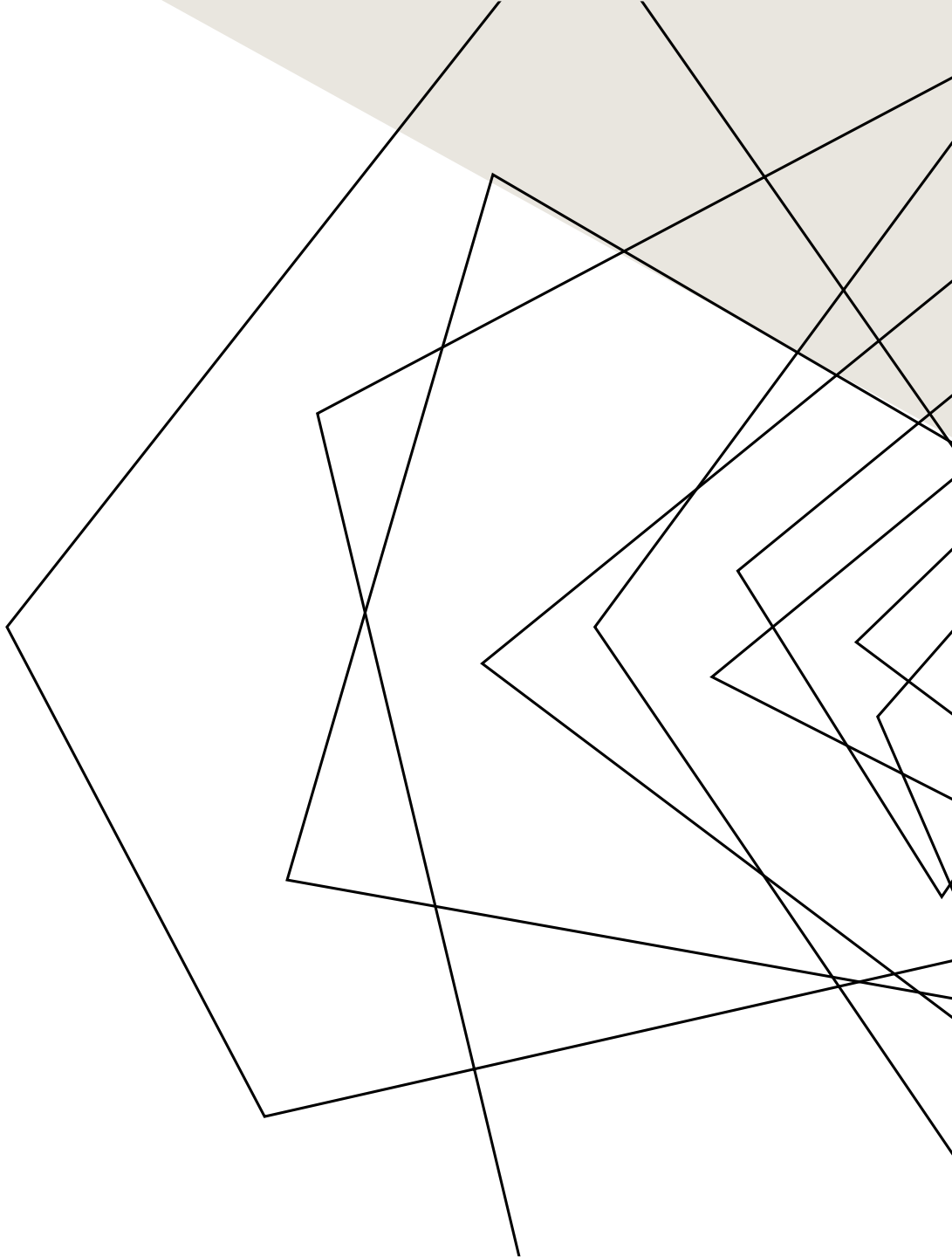
A FEW NOTES ON MYTHIC

- Open Source
- Developed by Cody Thomas
  - https://github.com/its-a-feature
- Sponsored by SpecterOps
  - https://github.com/specterops#mythic
- Application components run on Docker
- Designed for multiple concurrent users and engagements
- Operators connect to Mythic via browser



SCENARIO SETUP

- Modified Forest from Hack The Box for this demo
    - Out of capacity on home server 😭
- Solved box, logged in with DA NTLM Hash
- Added WinterKnight1337 user
- Added WinterKnight1337 user to Remote Management Users





MYTHIC SETUP

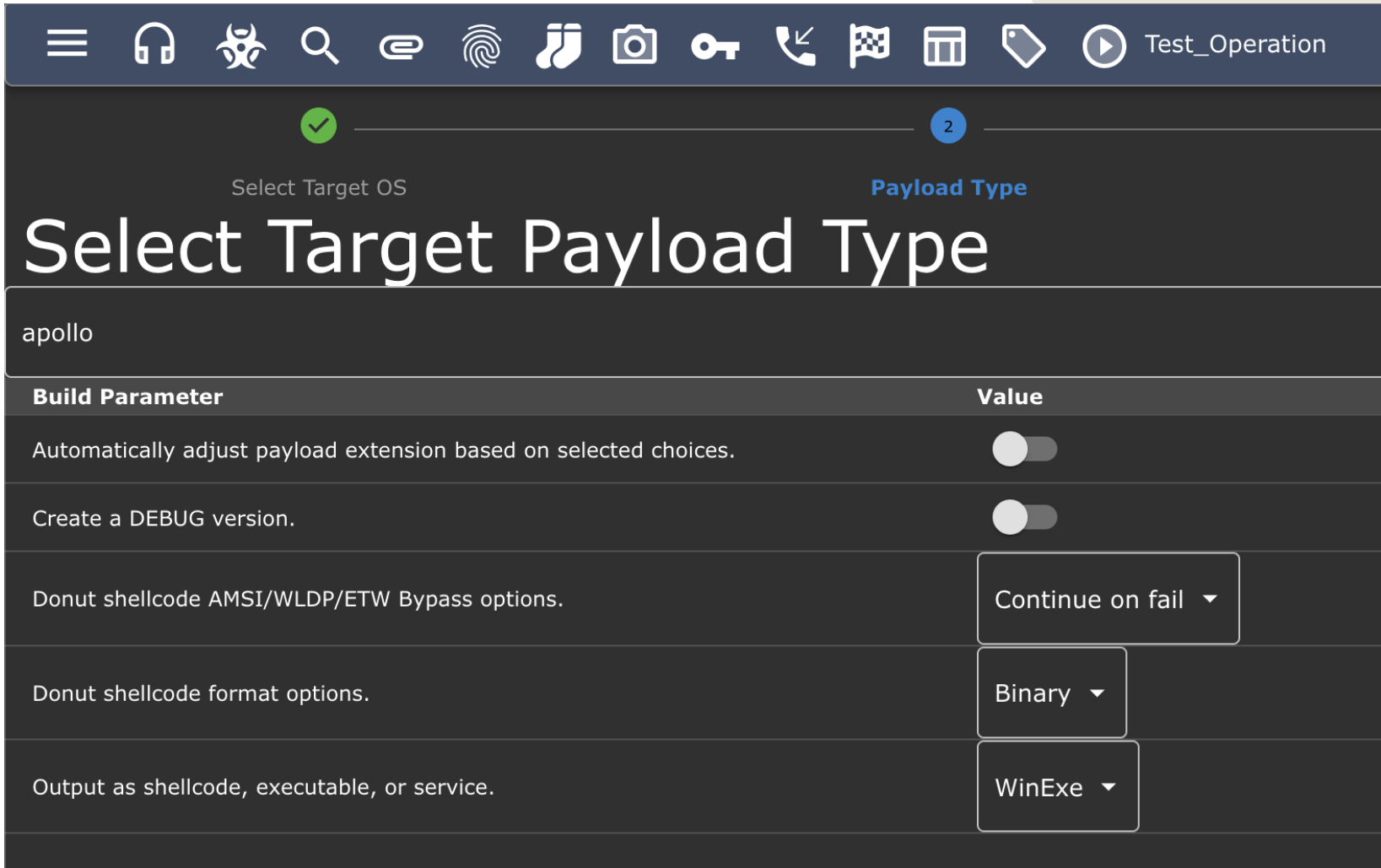
MYTHIC SETUP

```
┌──(winterknight㉿kali)-[/opt/Mythic]
└─$ docker ps
CONTAINER ID   IMAGE                                                COMMAND                  CREATED       STATUS
                         NAMES
05665da3a400   ghcr.io/its-a-feature/mythic_documentation:v3.3.0.84   "/bin/sh -c 'hugo se…"   40 hours ago   Up 3 hours (healthy)
                         mythic_documentation
ac9074d6068b   ghcr.io/mythicagents/athena:v2.2.1-rc8               "python3 /Mythic/mai…"   40 hours ago   Up 3 hours
                         athena
3ac8efd72d77   ghcr.io/mythicc2profiles/smb:v0.0.8                  "python3 main.py"        40 hours ago   Up 3 hours
                         smb
39959fe69880   ghcr.io/mythicc2profiles/http:v0.0.2.12              "/bin/sh -c 'make ru…"   40 hours ago   Up 3 hours
                         http
47a338f1a658   ghcr.io/mythicagents/apollo:v0.0.0.33                "bash -c 'cp /donut …"   40 hours ago   Up 3 hours
                         apollo
8f4db9efb793   ghcr.io/its-a-feature/mythic_postgres:v3.3.0.84      "docker-entrypoint.s…"   40 hours ago   Up 3 hours (healthy)
                         mythic_postgres
ce3304f3454b   ghcr.io/its-a-feature/mythic_react:v3.3.0.84         "/docker-entrypoint.…"   40 hours ago   Up 3 hours (healthy)
                         mythic_react
692192512fc6   ghcr.io/its-a-feature/mythic_graphql:v3.3.0.84       "docker-entrypoint.s…"   40 hours ago   Up 3 hours (healthy)
                         mythic_graphql
df81803ba179   ghcr.io/its-a-feature/mythic_rabbitmq:v3.3.0.84      "docker-entrypoint.s…"   40 hours ago   Up 3 hours (healthy)
 127.0.0.1:5672->5672/tcp   mythic_rabbitmq
450cd9a94047   ghcr.io/its-a-feature/mythic_jupyter:v3.3.0.84       "tini -g -- /bin/bas…"   40 hours ago   Up 3 hours (healthy)
                         mythic_jupyter
89c6d552e385   ghcr.io/its-a-feature/mythic_nginx:v3.3.0.84         "/docker-entrypoint.…"   40 hours ago   Up 3 hours (healthy)
                         mythic_nginx
857e9abc3bec   ghcr.io/its-a-feature/mythic_server:v3.3.0.84        "/bin/sh -c 'cp /myt…"   40 hours ago   Up 3 hours (healthy)
-17444/tcp               mythic_server
```

- Instructions followed from here - https://docs.mythic-c2.net/
- Pulled repo
- Installed docker
- Built mythic-cli executable
- Started Mythic using mythic-cli

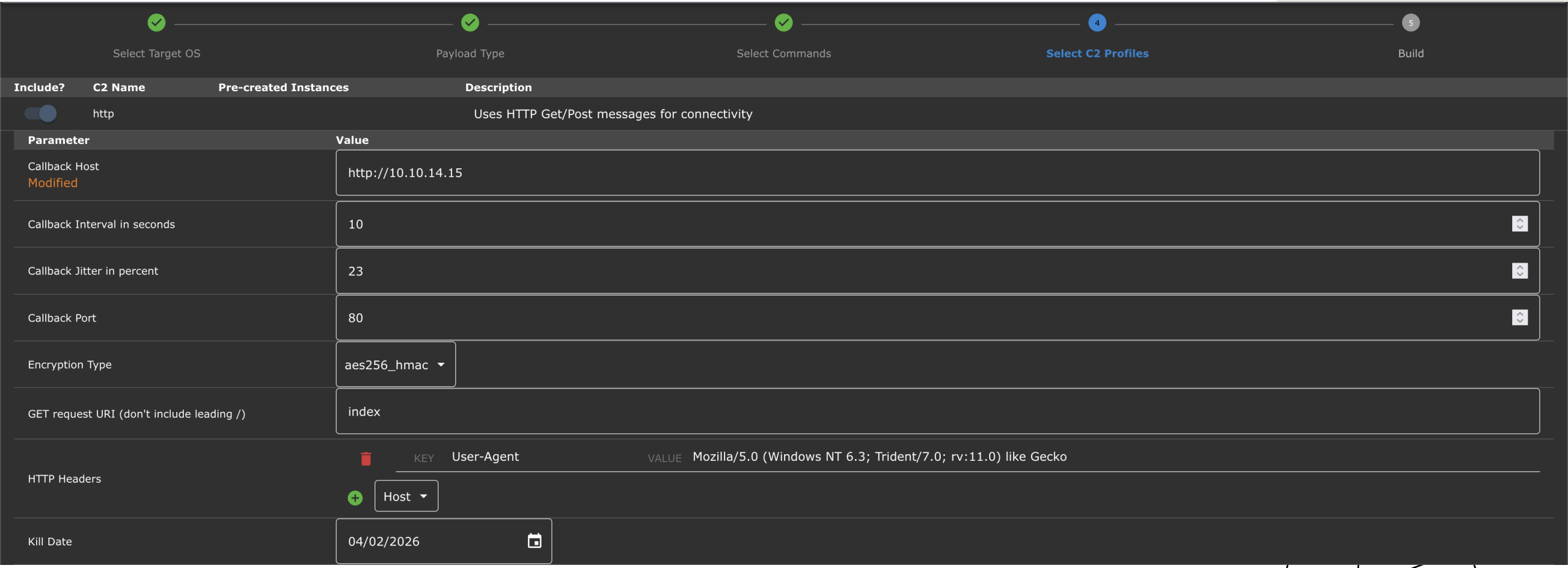
MYTHIC SETUP – APOLLO

- Using mythic_admin user (because I am lazy)
- Added Apollo (Windows Agent)
- Generated apollo.exe (With all commands)
- Uploaded and executed apollo.exe as winterknight1337 user



MYTHIC SETUP – APOLLO

10.10.14.15 is VPN tunnel address



MYTHIC SETUP – APOLLO

- Callback Successful!



What now? Well. Hacking!

MYTHIC USAGE

- More frequent communication with C2 server
  - 5 Seconds rather than 10
- Start with some simple enumeration with built-in commands
  - whoami
  - getprivs
- Before moving to more advanced enumeration

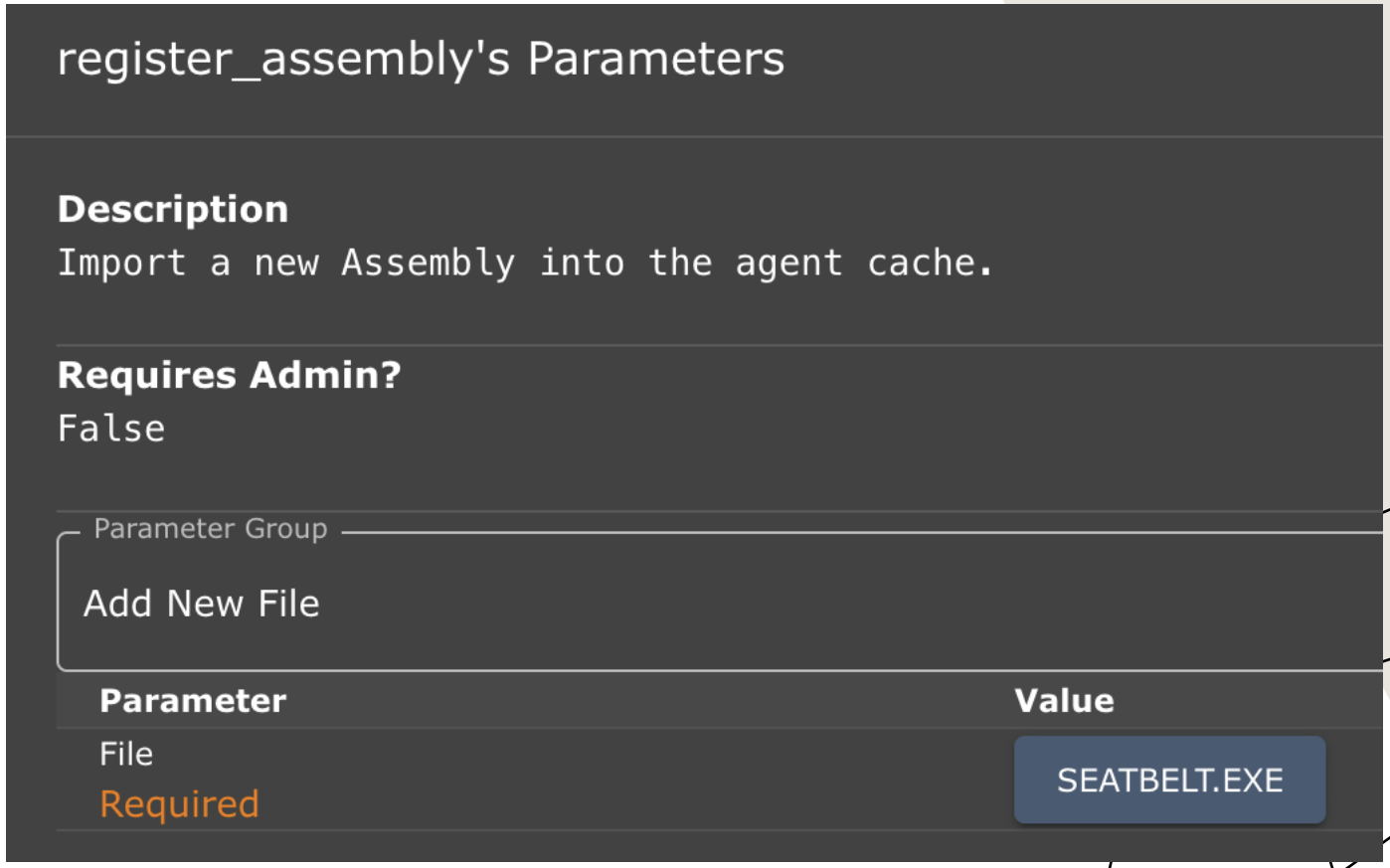
```
[Wed Apr 02 2025 02:23 PM] / T-22 / WinterKnight / C-3 / apollo /
getprivs
1  Impersonation identity enabled privileges:
2  SeChangeNotifyPrivilege
3  SeIncreaseWorkingSetPrivilege
4  SeMachineAccountPrivilege
5
6  Primary identity enabled privileges:
7  SeChangeNotifyPrivilege
8  SeIncreaseWorkingSetPrivilege
9  SeMachineAccountPrivilege
```

```
[Wed Apr 02 2025 02:28 PM] / T-23 / WinterKnight / C-3 / apollo /
sleep {"interval":5}
1
```

```
[Wed Apr 02 2025 02:28 PM] / T-24 / WinterKnight / C-3 / apollo /
whoami
1  Local Identity: HTB\winterknight1337
2  Impersonation Identity: HTB\winterknight1337
```

MYTHIC USAGE - HOST ENUMERATION

- Mythic requires registering external executables before use
- Once registered, executable can be run with execute-assembly
- Seatbelt.exe = host enumeration tool
- Seatbelt source located here https://github.com/GhostPack/Seatbelt
  - Note you must build the .sln yourself

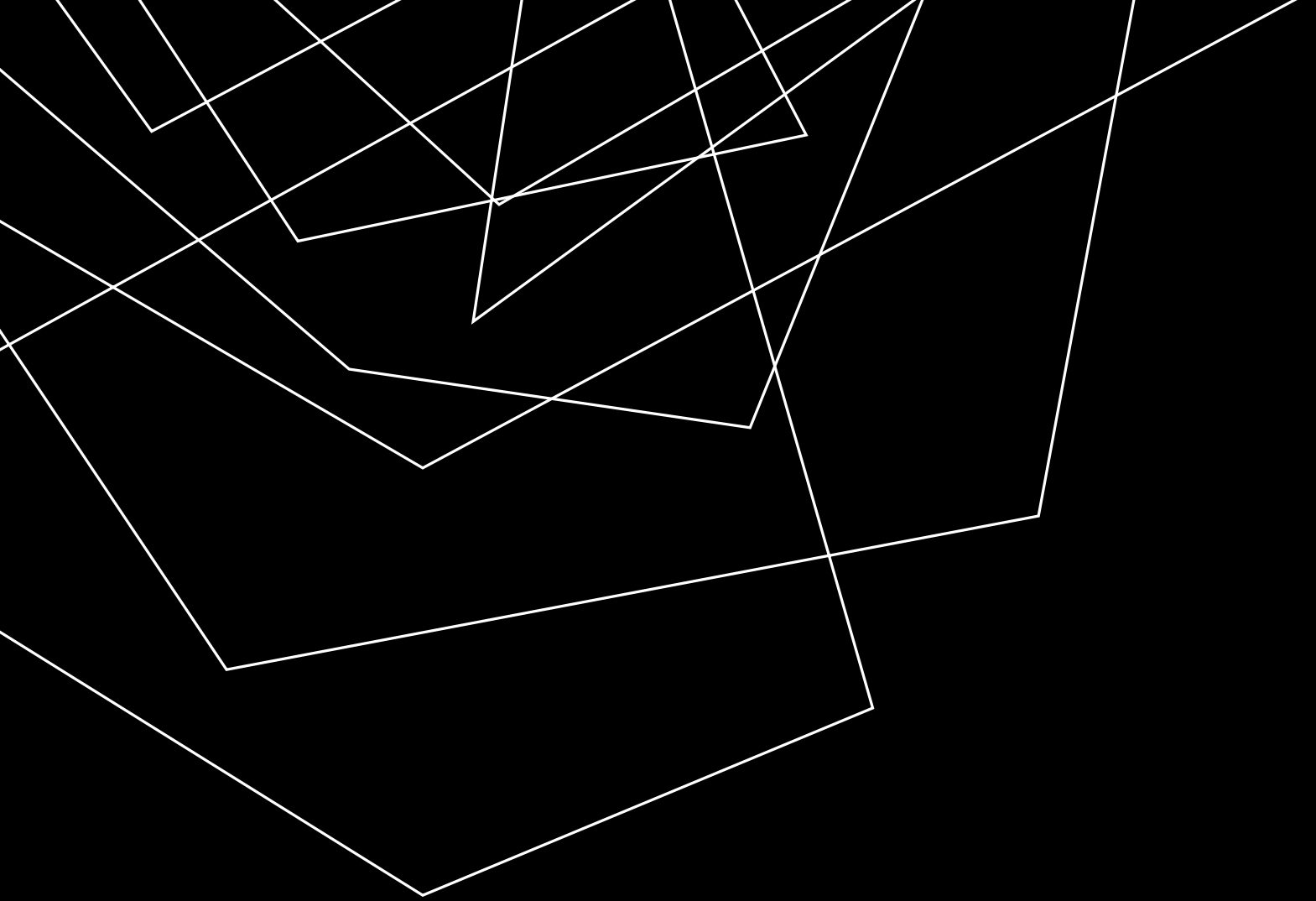


MYTHIC USAGE – RUNNING SEATBELT.EXE

- Seatbelt queries system for information based on operator's CLI args
- Returns output to C2 console

```
[Wed Apr 02 2025 02:38 PM] / T-27 / WinterKnight / C-3 / apollo /
execute_assembly -Assembly Seatbelt.exe -Arguments -group=system
257 ====== LocalUsers ======
258
259   ComputerName                  : localhost
260   UserName                      : Administrator
261   Enabled                       : True
262   Rid                           : 500
263   UserType                      : Administrator
264   Comment                       : Built-in account for administering the computer/domain
265   PwdLastSet                    : 8/30/2021 5:51:58 PM
266   LastLogon                     : 4/2/2025 9:37:00 AM
267   NumLogins                     : 125
268
269   ComputerName                  : localhost
270   UserName                      : Guest
271   Enabled                       : False
272   Rid                           : 501
273   UserType                      : Guest
274   Comment                       : Built-in account for guest access to the computer/domain
275   PwdLastSet                    : 1/1/1970 12:00:00 AM
```

```
[Wed Apr 02 2025 02:40 PM] / T-28 / WinterKnight / C-3 / apollo /
execute_assembly -Assembly Seatbelt.exe -Arguments -group=user
164 ====== TokenGroups ======
165
166 Current Token's Groups
167
168   HTB\Domain Users                            S-1-5-21-3072663084-364016917-1341370565-513
169   Everyone                                    S-1-1-0
170   BUILTIN\Remote Management Users             S-1-5-32-580
171   BUILTIN\Remote Desktop Users                S-1-5-32-555
172   BUILTIN\Users                               S-1-5-32-545
173   BUILTIN\Pre-Windows 2000 Compatible Access S-1-5-32-554
174   NT AUTHORITY\NETWORK                        S-1-5-2
175   NT AUTHORITY\Authenticated Users            S-1-5-11
176   NT AUTHORITY\This Organization              S-1-5-15
177   NT AUTHORITY\NTLM Authentication            S-1-5-64-10
```



THANK YOU!